Université de Perpignan
C. Negre

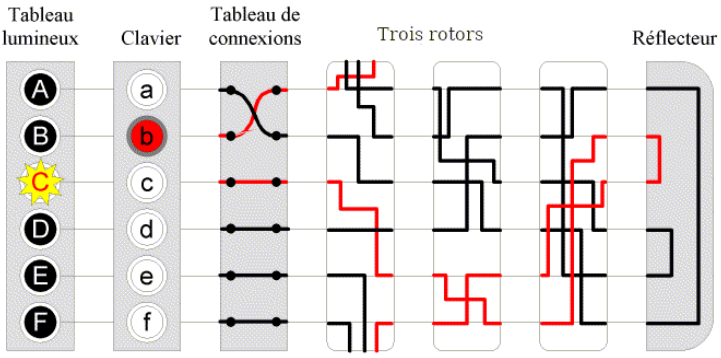
Année 2024

CC1 de Sécurité

Recommandations.

- Durée : 3h00.
- Seuls les documents fournis sont autorisés.
- Pour les exercices 2 et 3 vous rendrez, au choix une copie papier ou numérique. Pour l'exercice 1 vous rendrez votre code C sous format numériques. Le fichier doit contenir votre nom.

Exercice 1. Objectifs : Implanter le chiffrement/déchiffrement Enigma et monter une attaque basée sur l'indice de coincidence. Le schéma du chiffrement Enigma est décrit dans la figure ci-dessous.



- Tableau de connexion : il y a 6 connexions qui permettent d'échanger des lettres (par exemple si une connexion entre C et N alors C est substitué par N et N substitué par C).
- Le réflecteur échange les lettres en miroir: $A \leftrightarrow Z$, $B \leftrightarrow Y$, ...
- Les rotorts sont des substitutions de l'alphabet. Mais ils sont tournés d'un cran (à chaque tour pour le premier rotor, tous les 26 tours pour le second et tous les 26*26 tours pour le troisième).

Le squelette du programme C à compléter est dans le fichier `tp-enigma.c` sur le moodle du cours.

1. **Chiffrement Enigma.**

   (a) La clef est donnée par la structure suivante

```
struct key{
  int pos[3]; // 3 entiers dans 0..25 qui donnent les positions initiales
              // des rotors RI,RII,RIII
  int connecteur[6][2]; // les 6  connecteurs :
                        // la lettre connecteur[i][0] est échangée
                        // avec  la lettre connecteur[i][1]
};
```

   (b) Les trois rotors et le réflecteur sont donnés par les tableaux suivants :

```
// RI
int RI[26]={9,6,3,16,14,23,20,18,2,0,12,8,5,17,21,19,15,13,4,22,10,1,11,25,24,7};
int inv_RI[26]={9,21,8,2,18,12,1,25,11,0,20,22,10,17,4,16,3,13,7,15,6,14,19,5,24,23};
// RII
int RII[26]={13,19,25,15,18,5,1,14,10,12,22,17,2,9,3,8,21,11,0,4,24,20,23,7,6,16};
int inv_RII[26]={18,6,12,14,19,5,24,23,15,13,8,17,9,0,7,3,25,11,4,1,21,16,10,22,20,2};
// RIII
int RIII[26]={9,21,8,20,1,7,19,2,3,24,0,10,4,16,25,15,14,18,6,23,13,17,12,22,5,11};
int inv_RIII[26]={10,4,7,8,12,24,18,5,2,0,11,25,22,20,16,15,13,21,17,6,3,1,23,19,9,14};
// reflecteur
int reflecteur[26]={24,17,20,7,16,18,11,3,15,23,13,6,14,10,12,8,4,1,5,25,2,22,21,9,0,19};
```

substituer une lettre `c` (entier dans 0,..25) par `RI` consiste à calculer `u=RI[c]`.

(c) Compléter la fonction `chiffrement` pour que pour la i-ème lettre du message clair, on applique successivement:

- Les connecteurs.
- Les trois rotors `RI,RII` et `RIII` dans les bonnes positions.
- Le réflecteur.
- Les trois rotors `invRIII,invRII` et `invRI` dans les bonnes positions.
- Les connecteurs.

2. **Analyse d'Enigma.** On a un message C chiffré avec Enigma (vous le génèrerez avec la question 1 dans un premier temps). On admet le résultat suivant: si l'on déchiffrement un message avec

- les rotors bien positionnés ,
- sans connecteurs en début et en fin de chiffrement.

alors la fréquence des lettres du message M' obtenu est le suivant :

$$g_i = \left(\frac{12}{26} \times \frac{1}{26} + \frac{14}{26} \times f_i\right) \text{ pour } i \in \{0, 1, \ldots, 25\} \tag{1}$$

où f_i est la fréquence de la lettre i en français. Les f_i se déduisent du tableau ci-dessous donnant les pourcentages:

```
double pourcentages_francais[26]={9.42, 1.02, 2.64, 3.39, 15.87, 0.95,
1.04, 0.77, 8.41, 0.89, 0.00, 5.34, 3.24, 7.15, 5.14, 2.86, 1.06,
 6.46, 7.90, 7.26, 6.24,  2.15, 0.00, 0.30, 0.24, 0.32};
```

Si les rotors sont mal positionnés les fréquences des lettre du message M' seront tous plus ou moins égale à 1/26.

(a) Fonction `indice_confiance` : cette fonction prend un message (char *) en parametre et calcule :

- Les fréquences f'_i d'apparition dans le message M' pour chaque lettre de l'alphabet $i = 0, \ldots, 25$.
- Calcule et renvoie le réél (`double`) suivant :

$$IndConf = \left| (\sum_{i=0}^{25} (f'_i \times 100)^2) - (\sum_{i=0}^{25} (g_i \times 100)^2) \right|$$

où g_i est donné par (1). Remarque : ici pour des raisons de précision de calcul il vaut mieux faire des calcul avec des pourcentages.

(b) Fonction `analyse` : prend un message chiffré. Et pour toutes les positions des trois rotors,

- il déchiffre le message C (juste avec les rotors positionnés et sans connecteurs) et calcule l'indice de confiance à partir du message M' obtenu.

- il se souvient de la position des rotors qui donne l'indice de confiance le plus faible.

(c) vous tezrez l'attaque et vérifierez si les positions des rotors trouvées sont les bonnes (celles que vous avez utilisées pour chiffrer votre message).

Exercice 2 (Cryptographie à clef publique (5 points))**.** Supposons que l'administrateur système dans une organisation donne le même modulo RSA (par simplicité) à tous les utilisateurs et génère des exposants publiques et privés pour chaque utilisateur. Nous allons voir que c'est une faille de sécurité.

Soient deux utilisateurs Bob et Bernard qui ont pour clef publique N, e_1 et N, e_2, respectivement. Supposons qu'en plus $\text{pgcd}(e_1, e_2) = 1$. Supposons qu'Alice communique de façon confidentielle le même message m à Bob et Bernard:

- Alice chiffre m en c_1 avec la clef publique RSA de Bob. Elle l'envoie ensuite à Bob.
- Alice chiffre m en c_2 avec la clef publique RSA de Bernard. Elle l'envoie ensuite à Bernard.

Répondre aux questions suivantes.

1. On se place ici dans le cas où $e_1 = 7, e_2 = 17$ et $N = 5293$. Choisir un message m quelconque et calculer c_1 et c_2 le chiffré de m suivant e_1 et e_2 respectivement.
2. Déterminer u_1 et u_2 (relation de Bezout) pour $e_1 = 7$ et $e_2 = 17$ tels que
$$u_1 e_1 + u_2 e_2 = 1.$$
3. En utilisant la question 2 expliquer ce que vaut $(c_1^{u_1} \times c_2^{u_2}) \mod N$ (Indication: remplacer c_i par son expression en fonction de m et e_i).
4. On suppose maintenant que Bob et Bernard ont système RSA qui est robuste (i.e., $N \geq 2^{1024}$) mais on tous deux le même module commun et des exposants satisfaisant $\text{pgcd}(e_1, e_2) = 1$. En déduire que si Eve intercepte c_1 et c_2, elle peut calculer m même si le système RSA lui-même est sûr utilisé de façon individuelle (i.e., Eve peut calculer m même sans avoir la clef privée de Bob ou Bernard ni la décomposition de N).

Correction. *1. On a l'expression binaire des exposants :* $e_1 = 2^0 + 2^1 + 2^2$ *et* $e_2 = 2^0 + 2^4$*, on choisi* $m = 4$*, et on cacule les carrés successifs de* m

$$\begin{array}{lcl}
m^{2^0} \mod N & = & m = 4 \\
m^{2^1} \mod N & = & m^2 \mod N = 16 \\
m^{2^2} \mod N & = & (m^2)^2 \mod N = 256 \\
m^{2^3} \mod N & = & (m^4)^2 \mod N = 465536 \mod 5293 = 2020 \\
m^{2^3} \mod N & = & (m^4)^2 \mod N = (2020^2) \mod 5293 = 4790
\end{array}$$

On calcule ensuite :

$$\begin{array}{lcl}
c_1 & = & m^{e_1} = m^{2^0} \times m^{2^1} \times m^{2^2} \mod N = \overbrace{4 \times 16}^{=32} \times 256 \mod 5293 = 2899 \\
c_2 & = & m^{e_2} = m^{2^0} \times m^{2^4} \mod N = 4 \times 4790 \mod 5293 = 3281
\end{array}$$

2. On applique Euclide étendu :

$$\begin{array}{lllll}
u_0 = 1 & v_0 = 0 & r_0 = 17 & \textit{satisfont} & u_0 e_1 + v_0 e_2 = r_0, \\
u_1 = 0 & v_1 = 1 & r_1 = 7 & \textit{satisfont} & u_1 e_1 + v_1 e_2 = r_1, \\
u_2 = 1 & v_2 = -2 & r_2 = 3 & \textit{satisfont} & u_2 e_1 + v_2 e_2 = r_2, \\
u_3 = -2 & v_3 = 5 & r_3 = 1 & \textit{satisfont} & u_3 e_1 + v_3 e_2 = r_3, \\
u_4 = 7 & v_3 = -17 & r_4 = 0 & \textit{satisfont} & u_3 e_1 + v_4 e_2 = r_4.
\end{array}$$

Donc la relation de Bezout cherchée est :

$$-2 \times 17 + 5 \times 7 = 1.$$

3. *On a*

$$\begin{aligned} c_1^{u_1} \times c_2^{u_2} \mod N &= (m^{e_1})^{u_1} \times (m^{e_2})^{u_2} \mod N \\ &= (m^{e_1 u_1 + e_2 u_2} \mod N \\ &= m^1 \mod N = m \end{aligned}$$

Donc $c_1^{u_1} \times c_2^{u_2} \mod N = m$.

4. *Si Eve connait* e_1 *et* e_2 *satisfaisant* $pgcd(e_1, e_2) = 1$ *alors il existe une relation de Bezout comme suit:*

$$u_1 e_1 + u_2 e_2 = 1$$

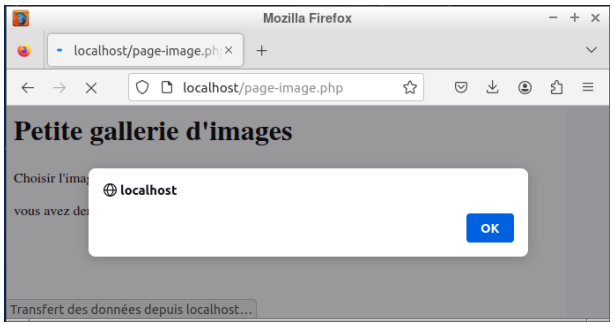
et cette relation de Bezout peut être calculée en temps polynomial avec l'algorithme d'Euclide étendu. Si Eve intercepte le chiffré c_1 *et* c_2 *d' un même message* m *elle peut retrouver ce message en calculant:*

$$c_1^{u_1} \times c_2^{u_2} \mod N = m^{e_1 u_1 + e_2 u_2} \mod N = m$$

Donc elle sait dans ce cas déchiffrer RSA sans avoir factorisé N.

Exercice 3 (injection Javascript/SQL)**.** Pour vos tests vous pouvez utiliser la machine virtuelle ubuntu. Pour rappel: login et mot de passe sont `l2info` et la base de données utilisée est aussi nommée `l2info`, pour se connecter à mysql faire dans le terminal `mysql -p l2info` et taper `l2info`). Les pages web et bases de données sont déjà présentes dessus.

1. Expliquez comment faire apparaitre une fenetre de type `alert` pour la page `page-image.php` comme dans la capture ci-dessous.



.

2. La page `page-image-protegee.php` empeche l'injection de la question 1: expliquez comment elle le fait. Proposez une méthode qui contourne cette protection en utilisant l'attribut `onerror` de la balise IMG pour faire apparaitre la fenetre alert.

3. La page `recherche.php` permet de rechercher des titres de livre en entrant un mot clef contenu dans le titre (dans la table Livres). Expliquez comment faire en sorte d'avoir sur la sortie la totalité de la table Users (comme dans la capture ci-dessous). Notez que vous pouvez si besion, réinitialiser la base de données avec `bd.sql`

.

Correction. 1. `<script> alert() </script>` *réponse vue en cours et en TD.*

2. *La page a été sécurisé en remplacant les* `<` *par des* `<` *et* `>` *des* `>` *rendant impossible d'injecter des balises, en particulier des balise de script. Pour faire l'injection, on met dans l'entree du formulaire*

```
31.jpg" onerror="alert()" alt="1
```

qui a pour effet de provoquer une erreur avec une image qui n'existe pas,le code pointé par onerror est alors exécuté.

3. *Il faut rendre vide la recherche normale sur le titre, en faisant un* `AND 0=1`*. Puis on fait une union avec un SELECT sur la table Users qui concatene toutes les données de la table Users. On termine par un* `#` *et un* `'` *pour fermer le* `'` *qui suivra dans le code php.*

```
Durant' AND '1'='0' UNION SELECT CONCAT(login,',',passwd,',',email) AS titre FROM Users; # '
```